Bug - cualquier jugador podía mover fichas ajenas - Servidor-Web-VPN

Introducción

Tras conseguir que el servidor Apache procesara PHP y se conectara con éxito a la base de datos MySQL en la red privada, procedí a realizar las pruebas de juego en tiempo real. Al simular una partida real utilizando dos pestañas de navegador distintas (simulando dos jugadores remotos), detecté un fallo crítico en la lógica de control que compromete la integridad de las partidas en un entorno abierto a internet.

Descripción del Bug

El error detectado permite que cualquier usuario manipule las piezas de su rival sin restricción alguna. Estando en el turno oficial de las piezas negras, el sistema permitía hacer clic en las piezas rojas y desplazarlas por el tablero como si fueran propias.

Este comportamiento rompe la mecánica básica del juego de damas y, lo que es más grave, permite que un jugador malintencionado sabotee la partida del oponente simplemente conociendo la URL de la misma.

Análisis de Seguridad: Local vs. Internet

Es fundamental entender por qué este fallo es crítico ahora y no lo era durante el desarrollo inicial:

- **Entorno Local (XAMPP):** Los dos jugadores comparten la misma máquina física y el mismo navegador. Existe una confianza implícita; no hay necesidad de validar quién es quién porque se asume que los jugadores están físicamente presentes y respetan el turno.
- **Entorno Sede Nube (AWS):** Al exponer el juego a internet, esa confianza desaparece. Cualquier persona con el enlace podría interferir. La arquitectura debe pasar a un modelo de Zero Trust (Confianza Cero), donde cada petición debe ser validada individualmente por el servidor.

Diagnóstico de las Causas

El problema no reside en un solo punto, sino en una falta de validación coordinada entre el backend y el frontend:

1. **Backend (api.php):** La API actual solo verifica si el movimiento es "legal" según las reglas de las damas (diagonales, capturas, etc.), pero no comprueba la identidad del

emisor. No existe un filtro que verifique si el token del jugador coincide con el color al que le toca mover.

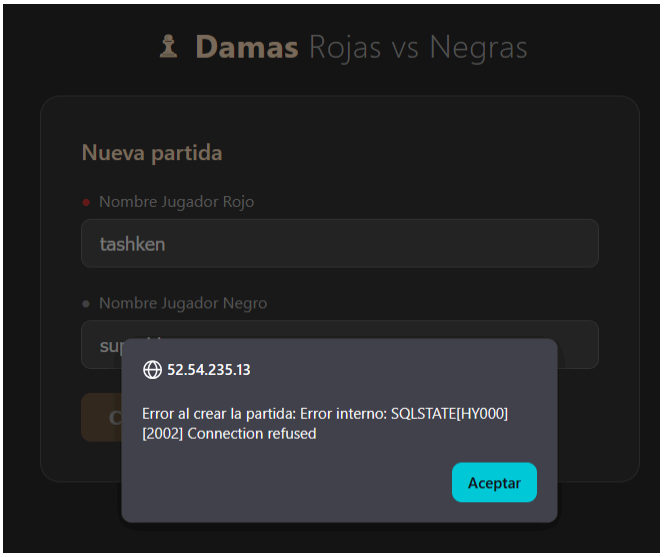
2. **Frontend (index.html):** La interfaz de usuario muestra todos los movimientos disponibles de forma global. No distingue qué jugador está mirando el tablero, permitiendo la interacción con cualquier pieza presente en el DOM.

Evidencias y Estado del Sistema

Durante las pruebas de corrección de este bug, se experimentaron también errores de conectividad derivados de la configuración del entorno dinámico, los cuales sirvieron para validar la robustez de los mensajes de error hacia el usuario.



(*Estado del lobby de "Nueva partida" antes de que la lógica de identificación por tokens fuera implementada para separar a los jugadores).*



(Error de conexión detectado durante el proceso de depuración de la API, confirmando que la seguridad de la red y el estado del servidor MySQL son requisitos previos para el correcto funcionamiento del sistema de validación).

Conclusión

La detección de la Issue marca un punto de inflexión en el desarrollo del TFG. Ha puesto de manifiesto que la infraestructura web no solo debe ser funcional, sino que debe implementar capas de seguridad lógica.

La resolución de este bug se abordará en la siguiente Issue , donde se implementará un nuevo sistema de tokens SHA-256 y un endpoint de identificación que bloquee cualquier movimiento que no provenga del jugador legítimo.